

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA5115 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I **M Nishanth (192511154)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: M Nishanth

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients
- B. Sensitive data must not be transmitted using SSL
- C. System downtime must be minimal during migration
- D. Cost of implementation should be optimized

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
- B. Compatibility with modern browsers is required
- C. Implementation complexity should be minimized
- D. Regulatory compliance (PCI-DSS) must be ensured

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Constraints:

- A. The network consists of 500+ interconnected systems
- B. Downtime per system should not exceed 10 minutes
- C. Detection must occur within 2 minutes of infection
- D. Solution must differentiate between virus, worm, and Trojan behavior

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Constraints:

- A. Must support both packet filtering and application-level inspection
- B. Latency introduced should not exceed 5 ms per request
- C. Should handle at least 1 Gbps traffic
- D. Must allow secure remote access for employees

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

Constraints:

- A. Detection accuracy must be at least 95%
- B. False positive rate should be reduced below 5%
- C. System must process real-time traffic of 2 Gbps
- D. Solution should integrate with existing firewall infrastructure

SIMATS ENGINEERING

ASSESSMENT TOOL 1 — CONSTRAINT-BASED PROBLEM SOLVING

Question 1: Migrating Legacy SSL Clients to TLS in a Financial Institution

Problem Understanding

A financial institution must move all web transactions to TLS, but roughly 20% of its client base still only supports older SSL versions, and the migration must not compromise sensitive data, incur excessive downtime, or exceed budget.

- The four constraints pull in different directions: Constraint A (backward compatibility) pushes toward keeping SSL support alive, while Constraint B (no sensitive data over SSL) demands the opposite for a defined subset of traffic — meaning the real requirement is not 'SSL or TLS' but selective, traffic-type-aware protocol enforcement.

Constraint Analysis and Prioritization

- Constraint B is treated as a hard, non-negotiable security/compliance constraint (SSL 3.0/early TLS have known cryptographic weaknesses such as POODLE, and PCI-DSS explicitly disallows their use for cardholder or authentication data) — it cannot be traded off against the others and is given the highest priority.
- Constraint A (20% legacy clients) is a real business constraint but is scoped: it justifies keeping SSL available only for non-sensitive functionality, not for any endpoint touching financial or authentication data.
- Constraint C (minimal downtime) and Constraint D (cost) are operational/resource constraints of secondary priority — they shape how the migration is implemented, not whether the security boundary in B is honored.

Solution Design

- Deploy TLS termination at a reverse proxy / load balancer layer in front of all application servers, so protocol handling is centralized rather than requiring changes to every backend system individually.
- Apply endpoint-based protocol tiering: sensitive endpoints (login, payments, account data, fund transfers) accept TLS 1.2+ only and immediately reject SSL/legacy-TLS handshake attempts with an 'upgrade required' response; non-sensitive endpoints (public marketing

pages, static content) continue to accept legacy SSL temporarily for the 20% of clients that need it.

- Roll out the proxy layer using a phased/rolling (blue-green) deployment across the load-balancer fleet so traffic is shifted gradually rather than through a single cut-over, keeping downtime minimal.
- Identify legacy clients via connection analytics and issue a time-bound upgrade notice; after the notice period, disable SSL support entirely, including for non-sensitive endpoints.
- Reuse existing reverse proxy/load balancer infrastructure to enforce these policies (cipher suite and protocol version configuration) rather than re-architecting each backend service, keeping implementation cost low.

Application of Concepts / Tools

- TLS 1.2/1.3 protocol negotiation and cipher suite configuration at a centralized reverse proxy layer.
- Traffic classification / endpoint-based policy enforcement to separate sensitive from non-sensitive data paths.
- Blue-green / rolling deployment as a change-management technique to minimize downtime during migration.

Justification

Prioritizing Constraint B above the others is justified because the cost and liability of a sensitive-data breach over a known-weak protocol (regulatory penalties, reputational damage, and PCI-DSS non-compliance) far outweighs the business cost of temporarily denying legacy clients access to sensitive functionality. The proxy-centralized approach satisfies Constraints C and D simultaneously, since protocol policy is enforced and changed in one place rather than across many legacy systems, minimizing both downtime and implementation cost.

Question 2: SET Protocol vs. TLS-Based Payment Security for E-Commerce

Problem Understanding

An e-commerce platform currently uses TLS-based encryption for payments and is considering adopting the Secure Electronic Transaction (SET) protocol instead, under throughput, browser-compatibility, complexity, and compliance constraints.

- SET was designed in the 1990s to provide strong mutual authentication between customer, merchant, and bank using dual signatures and certificates for all parties, but it requires specialized client-side 'digital wallet' software and never achieved broad industry adoption.

Constraint Analysis and Prioritization

- Constraint B (modern browser compatibility) is effectively disqualifying for SET: no modern browser natively supports the SET wallet software it requires, so meeting this constraint with SET would require distributing and maintaining custom client software for all customers — a non-starter for a public e-commerce platform.
- Constraint C (minimize implementation complexity) reinforces the same conclusion: SET's dual-signature, multi-certificate architecture is significantly more complex to implement and maintain than a standard TLS + tokenized-payment-gateway architecture.
- Constraint A (10,000 transactions/minute) and Constraint D (PCI-DSS compliance) are both comfortably achievable with a modern TLS-based architecture using standard, well-supported infrastructure, whereas SET was never optimized for this transaction volume and offers no compliance advantage that TLS plus tokenization does not already provide.

Solution Design

- Recommendation: continue with and strengthen the existing TLS-based approach rather than adopt SET.
- Upgrade/standardize on TLS 1.3 for all payment traffic to ensure strong, modern cryptography end to end.
- Adopt tokenization: replace the actual card number (PAN) with a non-sensitive token via the payment gateway/processor immediately at capture, so raw card data never touches or is stored on merchant servers, substantially reducing PCI-DSS scope.

- Route payment processing through a PCI-DSS Level 1 compliant third-party payment gateway, which shifts most compliance burden to a specialist provider rather than the merchant building compliant infrastructure from scratch.
- Add 3-D Secure 2.0 (3DS2) for cardholder authentication during checkout — this is the modern, browser/app-native equivalent of the authentication guarantee SET originally tried to provide, without requiring special wallet software.
- Scale to the required throughput using standard, well-understood techniques: load-balanced TLS termination and horizontally scaled payment-gateway integration.

Application of Concepts / Tools

- Comparative protocol analysis (SET vs. TLS) against explicit business and technical constraints.
- Tokenization and PCI-DSS scope reduction as a practical compliance strategy.
- 3-D Secure 2.0 as a modern cardholder-authentication mechanism.

Justification

SET is not recommended: it fails Constraint B outright (no viable client support in modern browsers) and performs poorly against Constraint C (high complexity relative to available alternatives), and neither of the remaining constraints (A, D) present any advantage for SET over the existing TLS-based approach. TLS combined with tokenization and 3DS2 meets all four stated constraints using industry-standard, actively maintained technology, which is why SET saw negligible real-world adoption and TLS-based payment security became the de facto standard.

Question 3: Containment and Prevention Strategy for Rapidly Spreading Malware

Problem Understanding

A corporate network of 500+ interconnected systems is experiencing malware infections that spread rapidly without any user interaction, requiring a containment and prevention strategy under tight detection and downtime windows.

- Spread with no user interaction is a strong behavioral indicator of worm-like self-propagation (as opposed to a virus, which typically needs a user to execute an infected file, or a trojan, which typically needs a user to install disguised software) — but the strategy must still

correctly differentiate all three, since a blended threat is possible and the correct containment action differs by type.

Constraint Analysis and Prioritization

- Constraint C (detection within 2 minutes) is treated as the foundational constraint: self-propagating malware can compromise a large fraction of a 500+ node network within minutes if undetected, so no downtime or containment budget can be met unless detection itself is fast — this must be solved first, and only automated detection (not manual monitoring) can realistically meet a 2-minute SLA.
- Constraint A (500+ systems) reinforces that response must be centrally automated rather than manual, since coordinating manual remediation across hundreds of hosts within minutes is not feasible.
- Constraint B (≤ 10 minutes downtime per system) rules out full reimaging as the default remediation path and instead requires fast, targeted remediation (isolation plus automated cleanup) for the majority of cases.
- Constraint D (differentiate virus/worm/Trojan) is applied as a classification step that determines which remediation playbook is triggered, since a one-size-fits-all response risks either leaving a network-based spread vector open (if treated only as a simple virus) or unnecessarily reimaging a system for a threat that could be cleanly removed (if treated only as a worm).

Solution Design

- Deploy network-based anomaly detection (IDS/IPS) tuned specifically for propagation patterns — e.g., a sudden spike in internal SMB/RPC connection attempts or port-scanning behavior across the LAN — to meet the 2-minute detection requirement.
- Implement automated micro-segmentation: on detection, the IPS automatically pushes dynamic VLAN/ACL changes to isolate the affected host or subnet without waiting for manual intervention, directly addressing the scale of 500+ systems.
- Deploy Endpoint Detection and Response (EDR) agents on all hosts to capture behavioral indicators locally: file-infection patterns (virus indicator), autonomous outbound connection attempts without user action (worm indicator), and disguised/backdoor process behavior (Trojan indicator).

- Feed these behavioral indicators into a classification step (a weighted-evidence approach, as used for malware typing) to select the correct remediation playbook: worm -> isolate + patch the propagation vector; virus -> quarantine + automated file-level cleaning or restore; Trojan -> isolate + terminate and remove the malicious process and its persistence mechanism.
- Use automated remediation (EDR-driven rollback to a known-clean state or targeted malicious-file removal) rather than manual reimaging, to keep per-system downtime within the 10-minute budget.
- Maintain a centralized SOC dashboard aggregating detection and remediation status across all systems for oversight and post-incident review.

Application of Concepts / Tools

- Network-based anomaly detection and automated micro-segmentation (SDN-style dynamic isolation).
- Endpoint Detection and Response (EDR) and behavioral malware classification (virus vs. worm vs. Trojan).
- Automated incident-response playbooks as a scalability mechanism.

Justification

Automation is justified at every stage because the combination of scale (500+ systems) and speed (2-minute detection, 10-minute remediation) makes manual response mathematically infeasible — a human-driven process cannot triage and act across hundreds of systems in these windows. Classifying malware type before remediation is justified because containment strategies are not interchangeable: applying a virus-cleaning approach to an active worm would leave the network propagation vector open, while applying network isolation alone to a Trojan would miss removing its backdoor persistence.

Question 4: Firewall Architecture for External Threats and Insider Attacks

Problem Understanding

An organization needs a firewall architecture that protects against both external threats and insider attacks, supports both packet filtering and application-level inspection, and must meet strict latency and throughput targets while enabling secure remote access.

- Protecting against insider attacks specifically means the architecture cannot rely on perimeter defense alone — internal (east-west) traffic between segments must also be inspected, not just traffic crossing the external boundary.

Constraint Analysis and Prioritization

- Constraints B (≤ 5 ms latency) and C (≥ 1 Gbps throughput) are treated as binding performance constraints that directly shape the architecture: applying full deep packet inspection to all traffic at this throughput risks exceeding the latency budget, so a single-technique design cannot satisfy Constraint A without violating B or C.
- Constraint A (packet filtering + application-level inspection) is therefore addressed with a tiered architecture rather than one universal technique, so each layer only does the amount of work its position in the pipeline can afford within the performance budget.
- Constraint D (secure remote access) is treated as a functional requirement that must be integrated into the same security perimeter rather than bolted on separately, so remote traffic is not an unmanaged bypass of the internal policy.

Solution Design

- Tier 1 — perimeter packet filter: a stateful, hardware-accelerated firewall handling bulk IP/port/protocol filtering at line rate, chosen specifically because ASIC-based packet filtering can sustain 1 Gbps+ with sub-millisecond latency, keeping the bulk of traffic within the 5 ms budget.
- Tier 2 — Next-Generation Firewall (NGFW) / application-layer inspection: deep packet inspection applied selectively (e.g., to HTTP/HTTPS/email traffic entering or leaving sensitive zones) rather than to all traffic uniformly, using hardware-accelerated NGFW appliances rated for the required throughput to keep added latency within budget.
- DMZ-based network design: external-facing servers are segmented into a DMZ, with the firewall pair mediating both external-to-DMZ and DMZ-to-internal traffic.

- Internal (east-west) segmentation: additional firewalling between internal VLANs/zones specifically to detect and contain insider or lateral-movement attacks that never cross the external perimeter at all.
- Secure remote access: an IPSec or TLS-based VPN concentrator integrated directly into the firewall stack, so remote employee traffic terminates at the same security boundary and is subject to the same internal policies as on-site traffic, combined with multi-factor authentication.
- Scale horizontally (multiple load-balanced firewall/NGFW instances) if a single appliance cannot meet the combined 1 Gbps / 5 ms target.

Application of Concepts / Tools

- Layered/defense-in-depth firewall design combining stateful packet filtering and NGFW/application-layer inspection.
- DMZ architecture and internal network segmentation for insider-threat mitigation.
- VPN integration (IPSec/TLS) with MFA for secure remote access.

Justification

A tiered architecture is justified because the four constraints cannot all be satisfied by a single technique: pure packet filtering alone cannot meet Constraint A's application-inspection requirement, while applying full deep inspection to all traffic at 1 Gbps risks violating the 5 ms latency budget in Constraint B. Splitting the work — fast filtering for the bulk of traffic, deep inspection reserved for higher-risk flows — is the standard way to meet both functional depth and performance constraints together. Adding internal segmentation directly addresses the insider-attack requirement that a perimeter-only design would miss entirely.

Question 5: Optimizing an IDS/IPS to Reduce False Positives and Alert Fatigue

Problem Understanding

A large enterprise network's IDS generates excessive false positives, causing alert fatigue among security analysts, and needs to be optimized to specific accuracy and false-positive targets while scaling to higher throughput and integrating with the existing firewall.

- The core tension is a precision/recall trade-off: naively raising detection thresholds to cut false positives (Constraint B) risks also missing genuine attacks, which would violate the 95% accuracy requirement (Constraint A) — the fix must improve the underlying signal quality, not simply shift a threshold.

Constraint Analysis and Prioritization

- Constraints A ($\geq 95\%$ accuracy) and B ($< 5\%$ false positive rate) must be treated together, not independently, since they represent opposite ends of the same trade-off; the solution is prioritized around improving detection quality itself (better features/correlation) rather than tuning a single sensitivity dial.
- Constraint C (2 Gbps real-time) is a performance constraint that rules out applying the most expensive analysis (e.g., full ML inference) to every packet, and instead requires a staged pipeline where cheap checks filter volume before expensive checks run.
- Constraint D (integrate with existing firewall) is treated as an architectural constraint requiring the new solution to be additive to, not a replacement for, the current firewall investment.

Solution Design

- Replace a single-technique detector with a multi-stage hybrid pipeline: fast signature-based matching first (high precision for known threats, minimal false positives on well-defined patterns), followed by machine-learning-based anomaly detection for traffic that signatures do not resolve (better distinguishes genuine anomalies from benign variation than simple static thresholds).
- Add a correlation/aggregation layer that only raises a full alert when multiple independent indicators agree, rather than acting on any single weak signal — directly reducing false positives caused by isolated, low-confidence signals.
- Continuously retrain the anomaly-detection baseline on recent legitimate traffic so the model adapts to evolving normal usage patterns, reducing false positives caused by baseline drift.

- Introduce alert tiering (critical / warning / informational) instead of a binary alert/no-alert output, so low-confidence signals are logged for monitoring rather than raised as full analyst-facing alerts — directly reducing perceived alert volume without discarding the underlying data.
- Establish an analyst feedback loop: confirmed false positives are fed back to retrain and tune the detection model over time (active learning), continuously improving the false-positive rate.
- Meet the 2 Gbps throughput target with staged processing: cheap signature/rule checks filter the bulk of traffic first, so the more expensive ML-based analysis only needs to process the smaller, already-narrowed subset of flagged traffic; distribute this pipeline across multiple parallel detection engine instances if needed.
- Integrate with the existing firewall by consuming mirrored/SPAN traffic for analysis and pushing confirmed block decisions back to the firewall via its management API, and by correlating IDS alerts with firewall logs for added context — extending the current infrastructure rather than replacing it.

Application of Concepts / Tools

- Hybrid signature-based and machine-learning-based intrusion detection.
- Multi-signal correlation / alert scoring to reduce false-positive rate without sacrificing recall.
- Staged/tiered processing pipelines as a technique for meeting high-throughput real-time constraints.

Justification

A multi-signal, ML-augmented approach is justified over simple threshold tuning because it improves the underlying signal-to-noise ratio, which is the only way to raise accuracy and lower the false-positive rate at the same time rather than trading one for the other. Staged processing (cheap filters before expensive analysis) is the standard pattern for sustaining high-throughput real-time detection without discarding depth of inspection, and integrating with — rather than replacing — the existing firewall preserves prior infrastructure investment while extending its effectiveness.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Problem Understanding	25%	Clearly defines the problem and identifies all relevant constraints accurately	Identifies most constraints with minor gaps	Partial understanding; misses key constraints	Fails to identify constraints correctly
Constraint Analysis	25%	Analyzes constraints effectively and prioritizes them logically	Provides reasonable analysis with some prioritization	Limited analysis; weak prioritization	No meaningful analysis or prioritization
Solution Development	25%	Develops optimal and feasible solutions	Develops workable solutions with minor limitations	Solutions partially satisfy constraints	Solutions do not meet constraints
		satisfying all constraints			
Application of Concepts	15%	Effectively applies appropriate concepts, methods, or tools	Applies concepts with minor errors	Limited application; requires guidance	Unable to apply relevant concepts
Justification	10%	Provides strong justification for decisions with logical reasoning	Provides justification with some clarity	Weak or unclear justification	No justification provided